

Som Chandra

somchandra.infosec@gmail.com | +91 9507988170 | github.com/somchandra17
linkedin.com/in/somchandra17 | tryhackme.com/p/somchandra17 | somm.tf

TECHNICAL SKILLS

Application and API Security: Gray-box web and API VAPT, OWASP Top 10, GraphQL security, CVSS scoring and SLA mapping

Mobile Offensive Security: Android and iOS SAST/DAST, OWASP MASTG/MASVS, Frida, objection, SSL pinning, root and jailbreak detection

Security Automation: Burp extension development (Montoya API, Extender API), Python, Kotlin, Java, FastAPI, VAPT to Jira

Attack Surface: subfinder, amass, httpx, testssl.sh, CVE checks before public templates, Nessus

Incident Response: Credential-exposure response, secrets inventory, read-only rotation checks

PROFESSIONAL EXPERIENCE

Cyber Security Engineer, MoveInSync – Bengaluru, India June 2025 – Present

- Reported 156 FY2025-26 VAPT findings across 10 internal cycles on employee-transport web, API, and Android products, including an unauthenticated API, IDOR in billing reports, and a WebSocket leaking live cab location
- Drove CVSS-to-SLA remediation with engineering across 180 reported tickets, with 100+ assigned and about 93% of assigned tickets closed
- Built a 9-phase Android DAST framework with adb, drozer, and apktool that cut per-app assessment from 1-2 days to under 1 hour, and that work contributed to the team declining a paid PortSwigger Burp DAST purchase
- Built GQLSweep, a Burp extension running 170+ automated GraphQL checks across 12 categories, surfacing alias-abuse denial of service and excessive data exposure later confirmed by an external vendor
- Owned external VAPT across 4 vendors and 4 major cycles on web, Android, iOS, and a driver app, including false-positive filtering, compensating controls the vendor accepted, and revalidation
- Built a Java Burp extension that decodes and re-encodes a zlib-compressed integer-array protocol, unlocking active testing of that traffic, and later ported the extension to the Montoya API
- Validated that an Android SSL-pinning bypass required a rooted, instrumented device and did not reproduce on the production build
- Ran the first in-house AI and LLM assessment of an internal chatbot, where prompt injection bypassed tool-persona and policy controls, and turned that work into a reusable method
- Drove credential-exposure response across 3,264 secret records, and a June 2026 read-only re-check found all 41 Slack webhooks and bot tokens still live after a claimed rotation
- Rewrote repository history so 13,784 leaked records in 201 files were dropped from the pushed branches
- Migrated Nessus from Azure Windows to hardened AWS Linux and automated weekly Advanced scans, with reports uploaded to Google Drive
- Built ExternalVAPT2JIRA and vapt-revalidator so VAPT findings become Jira tickets and IDOR and BAC retests run through Burp, and neither tool writes to Jira without human approval
- Manually validated Apache Tomcat CVE-2025-66614 and CVE-2026-24734 on UAT before public nuclei templates existed, and shared the results as a team reference

Technologies: Burp Suite, Frida, Python, Java, Nessus, FastAPI, AWS

Application Security Intern, MoveInSync – Bengaluru, India Jan 2025 – May 2025

- Raised critical reflected XSS findings on the transport-management API in an Apr-May 2025 manual and automated VAPT, and published the report
- Escalated critical issues to engineering leads the same day during a May 2025 production-clone assessment
- Surfaced a gap on an employee-data API call during a May 2025 authentication retrofit, and engineering wrapped the call in authentication

Technologies: Burp Suite, manual and automated API testing

- Cyber Security R&D Intern**, Securaeon Initiative – Remote Feb 2022 – July 2022
- Created security walkthroughs, proof-of-concept material, and practical lab content for upcoming cybersecurity products and courses
- Security Researcher**, Bugcrowd – Remote Oct 2021 – Dec 2021
- Reported web vulnerabilities through open bug bounty programs, and wrote impact, proof of concept, and remediation context for program security teams

PROJECTS

TrashDroid Mar 2026 – July 2026

github.com/Somchandra17/TrashDroid

- Published the Android DAST method as a 9-phase Python framework orchestrating adb, drozer, apktool, and sqlite3
- Covered exported-component SQL injection and path traversal, SQLite deep-dumps, logcat, heap and proc maps, ADB backup, manifest review, and secret detection
- Added Frida 17 bypasses for SSL pinning, root detection, and debugger detection, plus an AI-review triage package

Technologies: Python, adb, drozer, apktool, Frida

TrashiOS June 2026

github.com/Somchandra17/TrashiOS

- Published the iOS counterpart as a 13-phase SAST and DAST flow on a USB-connected jailbroken device
- Mapped checks to OWASP MASTG and MASVS and triaged an internal UAT iOS build into an AI-ready report

Technologies: Python, libimobiledevice, Frida, objection

Burp AI Agent Apr 2026

github.com/six2dez/burp-ai-agent

- Merged an NVIDIA NIM backend and a reworked OpenAI-compatible backend, including HTTP 429 handling, into six2dez/burp-ai-agent (PR 44)

Technologies: Kotlin

TrashRecon Mar 2026 – June 2026

github.com/Somchandra17/TrashRecon

- Dockerized external recon across 17 tools and 10 phases, with resume support and structured JSON so finished tool outputs are skipped on rerun

Technologies: Python, Docker, nuclei

CERTIFICATIONS

eWPTXv2, eLearnSecurity Web Application Penetration Tester eXtreme Jan 2023

CompTIA Security+ (SY0-701) Dec 2024

ACHIEVEMENTS

- Earned Hall of Fame recognition from Mastercard for SSTI escalated to LFI (P1), Rakuten for session fixation (P2), and Chaturbate for stored XSS (P2)
- Received 20+ NCIIPC India responsible-disclosure acknowledgments for client-side authentication bypass, missing rate limits, XSS, SQL injection, and account takeover
- Ranked in the top 1% on TryHackMe
- Placed 5th at OWASPLPU CTF 2022, 9th at WTFCTF 2022, and 34th at RuCTF 2022

EDUCATION

B.Tech, Computer Science and Engineering (Hons.), Lovely Professional University – Jalandhar, India May 2025

- Specialized in cybersecurity and blockchain